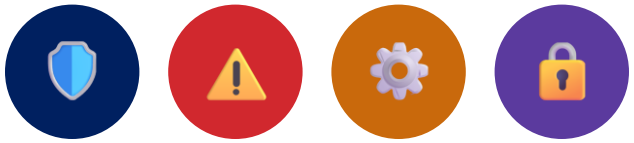
"Validate early. Handle gracefully. Respond consistently."

MODULE 29

Validation and Global Exception Handling

Learn how to validate input data and implement global exception handling in Spring Boot applications to build robust, secure, and user-friendly APIs.



TEKsystems Global Services

WORKFORCE DEVELOPMENT

WHY VALIDATION MATTERS

Validation is the first line of defense in any application. It ensures that only correct, safe, and meaningful data enters your system.

Goal: accept good data, reject bad data early, and provide clear feedback -- this leads to secure, reliable, and user-friendly applications.

Without Validation	With Validation
Invalid data accepted -- incorrect or incomplete data enters the system.	Good data accepted -- only valid, complete data enters the system.
Data quality issues -- corrupted records, inaccurate business data.	Better data quality -- consistent, accurate, reliable data.
Security vulnerabilities -- malicious input causes SQL injection, XSS, etc.	Stronger security -- blocks malicious or harmful input at the boundary.
Poor user experience -- users see errors or confusing messages later.	Better user experience -- clear, helpful messages and smooth interactions.
Higher maintenance cost -- fixing bad data, bugs, and exceptions costs time and money.	Lower cost & higher efficiency -- less rework, fewer errors, better productivity.

THE FOUR-WORD SUMMARY

Validate Early **Save Time** **Reduce Risk** **Deliver Quality**

KEY TAKEAWAY Validation helps you build secure, reliable, and user-friendly APIs by ensuring that the data your application processes is correct from the start.

MODULE LEARNING OBJECTIVES

By the end of this module, you will be able to implement robust validation and global exception handling in a Spring Boot application.

- **Understand Validation Fundamentals —** explain the importance of validation and the validation lifecycle in a Spring Boot application.
- **Use Bean Validation Annotations —** apply commonly used annotations such as @NotNull, @NotBlank, @Email, and @Size.
- **Apply Validation in Controllers —** integrate validation in REST controllers to ensure data integrity at the API boundary.
- **Handle Validation Errors —** return meaningful and user-friendly validation error messages to API consumers.
- **Implement Request Validation —** validate incoming request data using annotations and handle validation errors effectively.
- **Implement Global Exception Handling —** create centralized exception handling using @ControllerAdvice and @ExceptionHandler.
- **Design Standard Error Responses —** build consistent and user-friendly error response models with proper error codes and messages.
- **Follow Best Practices —** apply best practices for validation, logging, security, and exception handling in enterprise applications.

KEY TAKEAWAY You will be able to implement robust validation and global exception handling to build secure, reliable, and user-friendly Spring Boot applications.

INPUT VALIDATION OVERVIEW

Input validation is the process of verifying that incoming data is complete, correct, and in the expected format before it is processed.

WHY VALIDATE INPUT?

- **Prevents Invalid Data —** stops incomplete, incorrect, or malformed data from entering the system.
- **Enhances Security —** protects against threats like SQL injection, XSS, command injection, and more.
- **Ensures Data Quality —** maintains consistency and accuracy of stored and processed data.
- **Improves User Experience —** provides clear and helpful feedback about invalid inputs.
- **Reduces System Errors —** minimizes runtime exceptions and system failures caused by bad data.

VALIDATION IN THE REQUEST PROCESSING FLOW

VALIDATION CAN HAPPEN AT MULTIPLE LEVELS

- Client Side
- API/Controller
- Service Layer
- Database Layer

Good validation is the foundation of great applications: accurate data, a secure application, reliable processing, and a better user experience.

KEY TAKEAWAY Validate early, validate often! Always validate data at the boundaries of your application to build secure, reliable, and user-friendly systems.

VALIDATION LIFECYCLE

Validation happens at multiple points in the application lifecycle to ensure only correct and safe data is accepted and processed.

1. **Data Entry** — User input
2. **Input Reception** — App receives it
3. **Validation Execution** — Rules applied
4. **Validation Result** — Errors collected
5. **Decision** — Proceed or stop
6. **Processing** — If valid
7. **Response** — Success or errors

TYPES OF VALIDATION

Type	Where
Client-Side	Quick checks in the UI for instant feedback.
Server-Side	Primary validation in controllers/services.
Database	Constraints enforced at the database level.

BENEFITS OF A STRONG VALIDATION LIFECYCLE

- Improved Data Quality
- Enhanced Security
- Reduced Errors & Rework
- Better UX
- Higher Reliability

KEY TAKEAWAY Validate early, validate often. Catch issues as early as possible to save time and cost and improve user experience.

VALIDATION BEST PRACTICES

Following validation best practices helps ensure your application is secure, reliable, and provides a great user experience.

#	Practice	What It Means
1	Validate Early	Validate as early as possible in the request lifecycle; catch invalid data before it enters business logic.
2	Use Built-in Validation	Leverage Bean Validation annotations (@NotNull, @Size, @Email, etc.) instead of hand-rolled checks.
3	Keep Rules Consistent	Apply consistent rules across all layers; avoid duplicate or conflicting validations.
4	Provide Clear Messages	Return user-friendly, actionable error messages; avoid exposing internal details.
5	Validate for Security	Protect against malicious input (XSS, SQL injection, command injection); never trust client input.
6	Validate the Right Things	Validate only what is necessary; don't over-validate or hurt performance.
7	Centralize Validation	Use @Valid and @ControllerAdvice to centralize handling and keep one source of truth for errors.
8	Monitor and Improve	Log validation failures (without sensitive data); review and improve rules based on feedback.

DOs	DON'Ts
Use @Valid on request DTOs. Group related validations. Keep messages consistent. Test rules with unit/integration tests.	Don't trust client-side validation alone. Don't return stack traces. Don't skip validation for performance. Don't expose sensitive info in errors.

KEY TAKEAWAY Good validation is not just about catching errors -- it's about building secure, reliable, and user-friendly applications that keep data integrity and system trust.

BEAN VALIDATION FRAMEWORK

Bean Validation is a standard specification (JSR 380 / Jakarta Bean Validation) for validating Java objects using annotations.

1 **Annotations**
Define rules on DTOs

2 **Hibernate Validator**
Reference implementation

3 **Validation**
Applies rules, reports violations

WHAT IS BEAN VALIDATION?

- **Standard Specification —** JSR 380 (Jakarta Bean Validation) defines a standard for object validation.
- **Annotation-Based —** declares constraints on fields, methods, or classes.
- **Provider Implementation —** Hibernate Validator is the reference implementation used in Spring Boot.
- **Automatic & Consistent —** integrates with Spring MVC/Boot to validate automatically.

KEY COMPONENTS

- **Constraints —** predefined annotations like @NotNull, @Email, @Size, @Min.
- **Constraint Validators —** logic that checks if a value satisfies the constraint.
- **Validation Engine —** processes constraint metadata and performs validation.
- **Constraint Violations —** hold details of validation failures (field, message, invalid value).

HOW IT WORKS

- **1. Define Constraints —** add validation annotations to model/DTO classes.
- **2. Trigger Validation —** the framework validates the object (e.g. on an API request).
- **3. Evaluate Constraints —** each constraint validator checks the value against the rules.
- **4. Return Violations —** if any rule fails, violations are collected and returned.

BENEFITS

Reduces boilerplate code | **Consistent validation everywhere** | **Easy Spring integration** | **Clear, user-friendly errors**

KEY TAKEAWAY Bean Validation provides a powerful, standard, annotation-driven way to validate data, ensuring clean, consistent, and reliable applications.

BEAN VALIDATION ANNOTATIONS (1 OF 2)

@NotNull and @NotBlank: the two most common constraints for requiring a value to be present.

@NOTNULL -- PREVENTS NULL VALUES

Ensures a field, method parameter, or return value cannot be null. Applies to any reference type (String, Object, List). Does NOT apply to primitives (int, long).

Customer.java

```
@NotNull(message = "Name must not be null")
private String name;

@NotNull(message = "Email must not be null")
private String email;
```

On failure: a ConstraintViolationException (or MethodArgumentNotValidException on @RequestBody) is thrown, handled by the global exception handler with a 400 Bad Request.

@NOTBLANK -- PREVENTS EMPTY/BLANK STRINGS

Ensures a String is not null AND contains at least one non-whitespace character. Applies only to String types.

User.java

```
@NotBlank(message = "Username must not be blank")
private String username;

@NotBlank(message = "Email must not be blank")
private String email;
```

Input	@NotBlank Result
null	Invalid (fails)
"" (empty string)	Invalid (fails)
" " (spaces only)	Invalid (fails)
"John"	Valid

KEY TAKEAWAY Use @NotNull for any required reference type; use @NotBlank for required text so empty or whitespace-only strings are rejected too.

BEAN VALIDATION ANNOTATIONS (2 OF 2)

@Email and @Size: constraints for format correctness and length/count boundaries.

@EMAIL -- VALIDATES EMAIL FORMAT

Ensures a string is a well-formed email address (RFC 5322). String types only -- combine with @NotBlank for required, valid emails.

CustomerRequest -- combined usage

```
@NotBlank(message = "Email is required")
@Email(message = "Please provide a valid email")
private String email;
```

Input Value	@Email Result
user@example.com	Valid
user@sub.domain.com	Valid
userexample.com	Invalid (missing @)
user@.com / user@domain	Invalid (bad domain)

@SIZE -- VALIDATES LENGTH / ELEMENT COUNT

Validates a String, Collection, Map, or array's size against min/max boundaries (attributes: min, max, message).

User.java

```
@Size(min = 3, max = 30, message = "Username must be between 3 and 30
characters")
private String username;
@Size(min = 1, max = 5, message = "At least 1 and at most 5 roles allowed")
private List<String> roles;
```

Input (length)	@Size(min=3,max=10) Result
"Aman" (4)	Valid
"" (0)	Invalid (too small)
"This is a very long text" (24)	Invalid (too large)

KEY TAKEAWAY @Email validates format; @Size enforces length/count boundaries. Combine both with @NotBlank so fields are present, well-formed, and within range.

TRY IT YOURSELF — EXERCISE 1: DTO CONSTRAINT PLAN

Pre-lab Exercise 1 -- plan Bean Validation constraints for CustomerRequest's four core fields before writing any code.

STEP	WHAT TO DO
Goal	Plan Bean Validation constraints for CustomerRequest's four core fields before writing any code.
Field List	In notes/dto-constraints.md, write a constraint for each of: name, email, customerId, status.
Reference Check	Match your list to the reference: name -> @NotBlank; email -> @Email + @NotBlank; customerId -> @NotBlank + CUS-#### pattern; status -> @NotNull + allowed values.
Starter Dependency	Note that Lab 29 adds spring-boot-starter-validation to pom.xml -- the dependency that activates annotation-based validation.
Boundary	Do not implement the full CustomerRequest class yet -- this is a planning exercise, not a coding one.
Deliverable	notes/dto-constraints.md with all four fields constrained and the validation starter dependency named.

Reference -- target annotations (Lab 29 CustomerRequest)

```
@NotBlank(message = "Name is required")
private String name;
@NotBlank(message = "Email is required") @Email(message = "Please provide a valid email")
private String email;
@NotBlank @Pattern(regexp = "CUS-\\d{4}", message = "Must match CUS-####")
private String customerId;
@NotNull(message = "Status is required")
private CustomerStatus status;
```

TRY IT NOW Complete Exercise 1 before continuing -- see exercises/exercise-01-dto-constraints.md.

REQUEST VALIDATION WORKFLOW

In a Spring Boot application, incoming requests are automatically validated before the controller method body executes.

KEY POINTS

- Validation happens automatically -- no manual checks in the controller.
- All constraint violations are collected and reported together.
- Invalid requests never reach your business logic.
- Proper error responses improve API usability and client experience.

CustomerController.java

```
@PostMapping
public ResponseEntity<CustomerResponse> create(
    @Valid @RequestBody CustomerRequest request) {
  // @Valid triggers validation before this line runs
  return service.create(request);
}
```

KEY TAKEAWAY The request validation workflow ensures bad data is caught early, protecting your application and providing clear feedback to API clients.

HANDLING VALIDATION ERRORS

When validation fails, Spring throws a ConstraintViolationException or MethodArgumentNotValidException. Handle these to return clear, consistent responses.

COMMON VALIDATION EXCEPTIONS

- **MethodArgumentNotValidException —** thrown when validation fails for @RequestBody, @ModelAttribute, or @RequestPart objects.
- **ConstraintViolationException —** thrown when validation fails for @RequestParam, @PathVariable, or method parameters annotated with @Validated.

EXAMPLE ERROR RESPONSE

```
{
  "timestamp": "2026-07-14T12:00:00Z",
  "status": 400,
  "error": "Bad Request",
  "code": "VALIDATION_FAILED",
  "message": "Validation failed",
  "errors": [
    { "field": "email", "message": "must be a valid email" }
  ]
}
```

Centralized w/ @RestControllerAdvice **Consistent Structure**

Field-Level Messages **No Internal Details**

GlobalExceptionHandler.java

```
@RestControllerAdvice
public class GlobalExceptionHandler {
  @ExceptionHandler(MethodArgumentNotValidException.class)
  public ResponseEntity<ErrorResponse> handleValidation(
      MethodArgumentNotValidException ex) {
    var errors = ex.getBindingResult().getFieldErrors();
    return ResponseEntity.badRequest().body(
        ErrorResponse.of("VALIDATION_FAILED", errors));
  }
}
```

KEY TAKEAWAY Handle validation errors centrally to provide clear, consistent, and user-friendly feedback. This improves API reliability and client experience.

USER-FRIENDLY ERROR MESSAGES

Good error messages help users understand what went wrong and how to fix it -- clear, specific, and actionable, without exposing internal details.

Scenario	Bad Message (Confusing)	Good Message (Helpful)
Missing username	"Validation failed for field: username"	"Username is required."
Invalid email	"Invalid email format"	"Please enter a valid email address."
Username too short	"Size constraint violated"	"Username must be between 3 and 30 characters."
Weak password	"Password not valid"	"Password must be at least 8 characters and include a number and special character."
Date in past	"Invalid date"	"Date of birth must be in the past."

PRINCIPLES OF USER-FRIENDLY MESSAGES

Be Clear **Be Specific** **Be Actionable** **Be Consistent** **Be Safe**

KEY TAKEAWAY User-friendly error messages improve user experience, reduce support tickets, and build trust in your API.

EXCEPTION HANDLING REVIEW

Exception handling helps your application manage errors gracefully, maintain normal flow, and provide meaningful feedback when things go wrong.

TYPES OF EXCEPTIONS

- **Checked —** checked at compile time; must be caught or declared. Examples: IOException, SQLException.
- **Unchecked (Runtime) —** not checked at compile time, usually programming errors. Examples: NullPointerException, IllegalArgumentException.

EXCEPTION HIERARCHY (SIMPLIFIED)

- Throwable
  - Error -- serious problems the JVM can't handle.
  - Exception
    - Checked Exceptions (compile-time checked).
    - Runtime Exceptions (unchecked).

TRY-CATCH-FINALLY

```
try {
  // risky code here
} catch (SpecificEx e) {
  // handle specific first
} catch (Exception e) {
  // fallback for others
} finally {
  // always runs (cleanup)
}
```

WHEN TO THROW EXCEPTIONS

Invalid Input/State | **Business Rule Violations** | **External System Failures** | **Unexpected Internal Errors**

KEY TAKEAWAY Exception handling is not just about catching errors -- it's about building resilient applications that recover, respond, and keep users informed.

GLOBAL EXCEPTION HANDLING OVERVIEW

Global exception handling provides a centralized mechanism to handle exceptions across the entire application and return consistent responses.

1. **Client**
2. **Controller**
3. **Service / Repository**
4. **Exception Occurs**
5. **Global Handler**
6. **Error Response**

WHY GLOBAL EXCEPTION HANDLING?

Centralized

Handle all exceptions in a single location.

Consistent Responses

Return a uniform error structure across all APIs.

Cleaner Code

Controllers stay focused on business logic.

COMMON EXCEPTIONS HANDLED

Exception	When It Occurs
MethodArgumentNotValidException	@RequestBody / @ModelAttribute failed.
ConstraintViolationException	@RequestParam / @PathVariable failed.
ResourceNotFoundException	Requested resource not found.
Custom Business Exceptions	Domain rule violations.
Exception (generic)	Unexpected server errors.

KEY TAKEAWAY Global exception handling centralizes error management, ensures consistent and user-friendly responses, and improves reliability and user experience.

@CONTROLLERADVICE ANNOTATION

@ControllerAdvice is a specialization of @Component that lets you handle exceptions and customize responses globally across all controllers.

KEY FEATURES

- **Global Scope —** handles exceptions from all controllers in a single place.
- **Reusable Logic —** avoids code duplication across controllers.
- **Consistent Responses —** ensures a uniform error structure across the API.
- **Flexible Scoping —** can be applied to specific packages or controller groups.

GlobalExceptionHandler.java

```
@ControllerAdvice
public class GlobalExceptionHandler {

  @ExceptionHandler(IllegalArgumentException.class)
  public ResponseEntity<ErrorResponse> handleIllegalArgument(
      IllegalArgumentException ex) {
    ErrorResponse response = new ErrorResponse(
        "INVALID_ARGUMENT", ex.getMessage());
    return ResponseEntity.badRequest().body(response);
  }
}
```

KEY TAKEAWAY @ControllerAdvice helps you handle exceptions in one place, ensuring consistent, maintainable, and user-friendly error handling across your entire application.

@EXCEPTIONHANDLER ANNOTATION

@ExceptionHandler is used inside a @ControllerAdvice class to handle specific exceptions and return a custom response to the client.

HOW IT WORKS

1. **Exception**
2. **Advice Catches**
3. **Handler Executes**
4. **Response Returned**

Exception	Handled By
IllegalArgumentException	handleIllegalArgument() -> 400
ResourceNotFoundException	handleNotFound() -> 404
AccessDeniedException	handleAccessDenied() -> 403
Exception (generic)	handleGeneralException() -> 500

EXAMPLE: @EXCEPTIONHANDLER IN ACTION

```
@ControllerAdvice
public class GlobalExceptionHandler {

  @ExceptionHandler(ResourceNotFoundException.class)
  public ResponseEntity<ErrorResponse> handleNotFound(
      ResourceNotFoundException ex) {
    ErrorResponse response = new ErrorResponse(
        "RESOURCE_NOT_FOUND", ex.getMessage());
    return new ResponseEntity<>(response, HttpStatus.NOT_FOUND);
  }
  // multiple @ExceptionHandler methods can co-exist,
  // each targeting a different exception type
}
```

KEY TAKEAWAY @ExceptionHandler helps you handle specific exceptions in a global way, ensuring consistent, meaningful, and user-friendly error responses.

TRY IT YOURSELF — EXERCISE 2: HANDLER TODOS (STARTER)

Pre-lab Exercise 2 (fill-in-the-blank starter) -- complete a GlobalExceptionHandler sketch for validation and not-found.

STEP	WHAT TO DO
Goal	Complete a fill-in-the-blank GlobalExceptionHandler sketch that builds an ErrorResponse for validation and not-found failures.
Fill the Blanks	In notes/GlobalExceptionHandlerSketch.java, replace every _____ using the hints below.
Hints	@RestControllerAdvice; HttpStatus.BAD_REQUEST; correlation "lab-request-001"; HttpStatus.NOT_FOUND.
Controller Reminder	Write a note: controllers still need @Valid on @RequestBody -- without it, Bean Validation never runs.
Reflect	Confirm the happy-path GETs for CUS-1001 and CUS-1002 must still return 200 after these handlers exist.
Deliverable	GlobalExceptionHandlerSketch.java with every blank filled and the @Valid reminder written in notes.

notes/GlobalExceptionHandlerSketch.java -- STARTER (fill in every _____)

```
@_____
public class GlobalExceptionHandler {
  @ExceptionHandler(MethodArgumentNotValidException.class) @ResponseStatus(HttpStatus._____)
  ErrorResponse validation(MethodArgumentNotValidException ex) {
    return ErrorResponse.validation(_____, ex);  // TODO: include field violations
  }
  @ExceptionHandler(CustomerNotFoundException.class) @ResponseStatus(HttpStatus._____)
  ErrorResponse notFound(CustomerNotFoundException ex) {
    return ErrorResponse.notFound(ex.getCustomerId());
  }
}
```

TRY IT NOW Complete Exercise 2 before continuing -- see exercises/exercise-02-handler-todos.md.

STANDARD ERROR RESPONSE MODEL

A standard error response model ensures consistency across all APIs, making it easier for clients to understand, handle, and display errors.

Field	Description
timestamp	When the error occurred (ISO 8601 format).
status	HTTP status code.
error	Short reason phrase (e.g. Bad Request).
code	Application-specific error code.
message	Human-readable message for the client.
path	Request path where the error occurred.
correlationId / traceId	Unique request identifier for tracking.
errors / details	Optional field-level violation details.

Example Error Response (JSON)

```
{
  "timestamp": "2026-07-14T12:00:00Z",
  "status": 400,
  "error": "Bad Request",
  "code": "VALIDATION_FAILED",
  "message": "Validation failed",
  "path": "/api/customers",
  "correlationId": "lab-request-001",
  "errors": [
    { "field": "email", "message": "must be valid" },
    { "field": "age", "message": "must be positive" }
  ]
}
```

KEY TAKEAWAY A standard error response model brings consistency, clarity, and reliability to your APIs and improves the overall integration experience.

TRY IT YOURSELF — EXERCISE 3: ERROR RESPONSE ENVELOPE

Pre-lab Exercise 3 -- sketch the exact ErrorResponse JSON envelope for a 400 validation failure and a 404 not-found.

STEP	WHAT TO DO
Goal	Sketch the exact ErrorResponse JSON envelope for two real failure scenarios before any handler code exists.
Sketch #1 (400)	In notes/error-envelope.md, write a full validation-failure envelope, including violations and correlationId: "lab-request-001".
Reference Check	Confirm every required field appears: timestamp, status, error, message, path, correlationId, violations.
Sketch #2 (404)	Sketch the envelope returned for GET /api/customers/CUS-9999 when the customer does not exist.
Safety Check	Re-read both sketches -- confirm message never contains a stack trace, SQL fragment, or internal class/table name.
Deliverable	notes/error-envelope.md with a safety-checked 400 sketch and a 404 sketch.

Target shape -- 400 validation example

```
{
  "timestamp": "2026-07-27T09:15:00Z",
  "status": 400,
  "error": "Bad Request",
  "message": "Validation failed",
  "path": "/api/customers",
  "correlationId": "lab-request-001",
  "violations": [ { "field": "email", "message": "must be a valid email" } ]
}
```

TRY IT NOW Complete Exercise 3 before continuing -- see exercises/exercise-03-error-envelope.md.

ERROR CODES AND MESSAGES

Well-defined error codes and clear messages help clients understand what went wrong and how to fix the issue quickly.

Code	HTTP Status	Message	Description
VALIDATION_FAILED	400	Validation failed for one or more fields.	Request parameters or payload validation failed.
RESOURCE_NOT_FOUND	404	The requested resource was not found.	Resource does not exist or is unavailable.
ACCESS_DENIED / UNAUTHORIZED	403 / 401	You do not have permission / authentication required.	Authenticated but not authorized, or missing auth.
DUPLICATE_RESOURCE	409	Resource already exists.	Attempt to create a duplicate resource.
INTERNAL_SERVER_ERROR	500	An unexpected error occurred. Please try again later.	Server-side unexpected condition.

MESSAGE DESIGN TIPS

Use simple language | **Explain what & how to fix** | **Include field-level details** | **Avoid internal jargon**

KEY TAKEAWAY Consistent error codes and user-friendly messages make your APIs easier to integrate, faster to troubleshoot, and better for everyone.

TRY IT YOURSELF — EXERCISE 4: EXCEPTION TO STATUS MAP

Pre-lab Exercise 4 -- map five real Lab 29 failure cases to the HTTP status code each should return.

STEP	WHAT TO DO
Goal	Document how each of five real Lab 29 failure cases maps to an HTTP status code.
Fill the Map	In notes/exception-status-map.md, map: Bean Validation failure, customer not found, duplicate create, illegal status transition, and unhandled exception.
Reference Check	Compare against: 400, 404, 409, 409-or-422, and 500 (safe fallback).
Justify	Pick 409 or 422 for illegal status transition and justify the choice in one sentence.
Handler Type	Note that all five cases are handled by one @RestControllerAdvice / GlobalExceptionHandler class, not five separate try/catch blocks.
Deliverable	notes/exception-status-map.md with all five cases mapped, the handler type named, and the transition justification written.

Reference -- exception-status-map.md

```
Bean Validation failure          -> 400 Bad Request
Customer not found (CUS-9999)    -> 404 Not Found
Duplicate create (CUS-1001)      -> 409 Conflict
Illegal status transition        -> 409 or 422 (justify your pick)
Unhandled exception              -> 500 Internal Server Error (safe fallback)
```

TRY IT NOW Complete Exercise 4 before continuing -- see exercises/exercise-04-exception-status-map.md.

API ERROR STANDARDS

Consistent error standards make APIs easier to implement, integrate, and support -- improving developer experience and system reliability.

STANDARD PRINCIPLES

- **Consistent —** use the same error structure and fields across all APIs.
- **Clear & Actionable —** provide clear messages that help clients understand and fix issues.
- **Secure —** do not expose internal details, stack traces, or sensitive data.
- **Appropriate —** use correct HTTP status codes for each error scenario.
- **Traceable —** include a correlation/trace ID to help track and troubleshoot issues.

HTTP STATUS CODE STANDARDS

Status	Meaning
400 Bad Request	Invalid request syntax or validation failure.
401 Unauthorized	Authentication required and has failed.
403 Forbidden	Authenticated but not authorized to access.
404 Not Found	Requested resource does not exist.
409 Conflict	Conflicts with current state (e.g. duplicate).
422 Unprocessable Entity	Semantic errors or business rule violations.
500 Internal Server Error	Unexpected server-side error.

ERROR CODE GUIDELINES

UPPER_SNAKE_CASE codes | **Unique, stable, documented** | **Grouped by domain (VALIDATION_*, AUTH_*)**

Never change published codes -- version instead

KEY TAKEAWAY Define and follow a consistent error standard across all APIs to ensure clarity, reliability, and better client integration.

LOGGING VALIDATION FAILURES

Logging validation failures helps teams quickly identify bad requests, analyze root causes, and improve data quality and API reliability.

WHAT TO LOG

- Timestamp, request/correlation ID, and client IP.
- HTTP method, request path, and status code returned.
- Validation error details: field, rejected value, message.
- User or client identifier, if available.

Never log sensitive data like passwords, tokens, or PII.

Logging inside the handler

```
@ExceptionHandler(MethodArgumentNotValidException.class)
public ResponseEntity<ErrorResponse> handleValidation(
    MethodArgumentNotValidException ex,
    @RequestHeader(value = "X-Correlation-Id",
        required = false) String requestId) {
  var errors = ex.getBindingResult().getFieldErrors();
  log.warn("VALIDATION_FAILURE | requestId={} errors={}",
      requestId, errors);
  return ResponseEntity.badRequest().body(
      ErrorResponse.of("VALIDATION_FAILED", errors));
}
```

BEST PRACTICES

- **Log at WARN level**
- **Use structured (JSON) logs**
- **Include a correlation ID**
- **Never log full request bodies**

KEY TAKEAWAY Logging validation failures with proper context and structure helps you monitor, secure, and improve your APIs for a better client experience.

VALIDATION AND SECURITY

Strong validation and security controls protect your APIs from invalid, malicious, and unauthorized requests while delivering clear feedback.

VALIDATION LAYERS (DEFENSE IN DEPTH)

1. **Client-Side**
   Instant UI feedback
2. **API Request**
   Bean Validation
3. **Service / Business**
   Business rules, state
4. **Database**
   Constraints, final safeguard

SECURITY CONTROLS

- **Authentication & Authorization —** verify identity (JWT/OAuth2) and permission before processing.
- **Input Validation & Sanitization —** validate all inputs; sanitize to prevent SQL injection and XSS.
- **Rate Limiting & HTTPS —** limit abusive requests; encrypt data in transit.

WHAT NOT TO DO

- Do not trust client-side validation only.
- Do not expose stack traces or internal system details.
- Do not log sensitive data (passwords, tokens, PII).
- Do not accept unexpected data silently.

KEY TAKEAWAY Robust validation and security protect your APIs, your data, and your users. Validate early, secure by design, and respond with clear, safe, consistent errors.

ERROR HANDLING BEST PRACTICES

Good error handling improves reliability, security, and user experience. Follow these best practices to build robust and maintainable APIs.

#	Practice	What It Means
1	Validate Early	Validate all inputs as early as possible and fail fast with meaningful messages.
2	Use Appropriate HTTP Status Codes	Return the correct status that matches the error type (400 bad request, 404 not found, etc.).
3	Use a Standard Error Response Model	Maintain a consistent structure with fields like timestamp, status, code, message, path, traceId.
4	Do Not Expose Internal Details	Avoid exposing stack traces, SQL queries, or internal class names in responses.
5	Log with Context	Log errors with requestId/traceId, userId, path, and useful metadata for faster troubleshooting.
6	Handle Exceptions at the Right Level	Handle exceptions at a central layer (@ControllerAdvice); avoid try-catch in every method.

BAD VS GOOD ERROR MESSAGE

Bad	Good
"Error while processing request" -- status 500, no detail, not actionable.	"Email must be a valid email address" -- status 400, clear, specific, actionable.

KEY TAKEAWAY Following error handling best practices ensures your APIs are reliable, secure, and user-friendly, while making them easier to monitor, debug, and maintain.

TRY IT YOURSELF — EXERCISE 5: LAB 29 READINESS CHECK

Pre-lab Exercise 5 (capstone) -- confirm lab29-crm is ready to start as the Week 3 error-contract capstone.

STEP	WHAT TO DO
Goal	Confirm lab29-crm is ready to start as the Week 3 error-contract capstone.
Dependencies	In notes/lab29-readiness.md, list the Lab 14 / Lab 16 concepts and the Lab 25-28 Spring Boot surface this lab builds on.
Project Path	Write down the real project path: examples/lab29-crm.
Evidence Plan	Plan curl evidence for 400, 404, and 409 responses, plus the happy paths for CUS-1001 and CUS-1002, all correlated via lab-request-001.
Week Boundary	Explicitly note that Week 4 topics (Kafka, React, PostgreSQL) are out of scope for this pre-lab and for Lab 29's timed path.
Deliverable	notes/lab29-readiness.md with dependencies listed, the project path written, and Week 4 explicitly excluded.

Evidence to capture before Lab 29

```
$ curl -i -X POST http://localhost:8080/api/customers -d '{...}'   // expect 400 + violations[]
$ curl -i http://localhost:8080/api/customers/CUS-9999             // expect 404 RESOURCE_NOT_FOUND
$ curl -i -X POST http://localhost:8080/api/customers -d '{...CUS-1001...}'  // expect 409 duplicate
$ curl -i http://localhost:8080/api/customers/CUS-1001             // expect 200, Amina Khan, ACTIVE
# Every response correlated via X-Correlation-Id: lab-request-001
```

TRY IT NOW Complete Exercise 5 before continuing -- see exercises/exercise-05-lab29-readiness.md.

LAB OVERVIEW -- VALIDATION AND EXCEPTION HANDLING

Lab 29: Validation and Exception Handling -- Northstar CRM Error Contracts

BUSINESS SCENARIO

- Agents and integrations will send bad JSON. Leadership freezes the rule: no API error path may return framework-default HTML stack traces or ad-hoc Map bodies to React.
- You own the contract for Amina (ACTIVE), Ravi (PROSPECT), unknown IDs, duplicates, and illegal lifecycle transitions.
- This unifies Lab 14's DTO/validation ideas and Lab 16's exception-handler ideas into one stable Spring Boot contract every client relies on.

LEARNING OBJECTIVES

- Annotate CRM request DTOs with Bean Validation constraints.
- Trigger validation with @Valid / @Validated on controller methods.
- Map field and object-level violations into a stable ErrorResponse.
- Centralize exception handling with @RestControllerAdvice / @ExceptionHandler.
- Align HTTP status codes with business exceptions (404, 409, 400/422).
- Preserve correlation IDs such as lab-request-001 in error responses.

WHAT YOU BUILD

- Copy lab28-crm to lab29-crm; add spring-boot-starter-validation; define ErrorResponse (+ FieldViolation); annotate CustomerRequest/StatusUpdateRequest; enable @Valid on controllers; implement GlobalExceptionHandler for validation, not-found, duplicate, illegal transition, and a safe 500 fallback; write MockMvc tests asserting status and body shape.

KEY TAKEAWAY Fixtures CUS-1001 (Amina Khan, ACTIVE) and CUS-1002 (Ravi Singh, PROSPECT) anchor every example; CUS-9999 proves not-found handling; correlation ID lab-request-001 appears on every error envelope.

LAB TASKS AND DELIVERABLES

Northstar CRM Error Contracts -- implementation steps, deliverables, and the evaluation rubric.

#	Implementation Step
1	Branch lab28-crm to lab29-crm; add spring-boot-starter-validation; define ErrorResponse + FieldViolation.
2	Annotate CustomerRequest (@NotBlank, @Pattern, @Email) and StatusUpdateRequest (@NotNull).
3	Enable @Valid on create and status-update controller methods.
4	Prove validation failures with curl -- observe framework-default, then custom envelope.
5	Implement GlobalExceptionHandler for MethodArgumentNotValidException -> 400.
6	Map domain exceptions: not-found -> 404, duplicate -> 409, illegal transition -> 400/422.
7	Add a safe generic Exception -> 500 fallback; log full detail server-side only.
8	Write MockMvc tests (status + jsonPath body); document a Lab 14/16 unify note.

EXPECTED DELIVERABLES

- lab29-crm with Bean Validation + GlobalExceptionHandler + ErrorResponse.
- Automated tests for validation and not-found envelopes.
- Successful-path evidence (CUS-1001, CUS-1002).
- Controlled-failure evidence (400/404/409 + envelope).
- Lab 14/16 unify note; no secrets or target/ committed.

RUBRIC (100 MARKS)

- Environment 10 · Core Impl 30 · Integration/Config 15 · Failure Handling 15 · Verification 10 · Security/Prod Awareness 10 · Docs 10

KEY TAKEAWAY Happy-path tests without envelope assertions are incomplete; leaking a stack trace to a client loses security/production marks even if the happy path works.

TRY IT YOURSELF — EXERCISE 6: MOCKMVC BODY ASSERTIONS

Pre-lab Exercise 6 -- plan MockMvc tests that assert JSON response fields, not just the HTTP status code.

STEP	WHAT TO DO
Goal	Plan MockMvc tests that assert JSON response fields, not just the HTTP status code.
Four Cases	In notes/mockmvc-body-plan.md list: invalid POST, GET CUS-9999, duplicate-create CUS-1001, and happy GET for Amina (CUS-1001).
Failure Assertions	For each failure case, name the assertions: status, message/error, and correlationId all exist in the body.
Security Coexistence	If Lab 28 security is complete, note that tests may need auth headers -- do not remove security to make a test pass.
Boundary	Do not implement full MockMvc test classes yet -- this is a planning exercise; Lab 29 builds the real tests.
Deliverable	notes/mockmvc-body-plan.md with all four cases and their envelope-field assertions listed.

Target assertion style (MockMvc + jsonPath)

```
mockMvc.perform(post("/api/customers")
        .contentType(APPLICATION_JSON).content(invalidCustomerJson))
    .andExpect(status().isBadRequest())
    .andExpect(jsonPath("$.status").value(400))
    .andExpect(jsonPath("$.correlationId").exists())
    .andExpect(jsonPath("$.violations").isArray());
```

TRY IT NOW Complete Exercise 6 before continuing -- see exercises/exercise-06-mockmvc-body-assertions.md.

MODULE 29 SUMMARY

In this module, we learned how to validate inputs, handle exceptions globally, and return standardized error responses to build secure, reliable, user-friendly APIs.

KEY CONCEPTS COVERED

Validate Early

Validate all inputs using Bean Validation (JSR 380) to catch invalid data early.

Handle Globally

Use @ControllerAdvice and @ExceptionHandler to handle exceptions across the API.

Consistent Error Model

Return a standard error response with timestamp, status, code, message, path, traceId.

Secure by Design

Never expose internal details or stack traces; log sensitive information securely.

Monitor & Improve

Log validation failures and exceptions with context to monitor and improve APIs.

Better User Experience

Provide clear, actionable error messages that help clients fix issues quickly.

MODULE FLOW RECAP

1. **Bean Validation**
2. **@Valid on Controllers**
3. **@ControllerAdvice**
4. **Standard ErrorResponse**
5. **Lab: Northstar CRM**

KEY TAKEAWAY Effective validation and global exception handling are essential for building enterprise-grade APIs. They ensure data integrity, system security, and a great developer and user experience.

KNOWLEDGE CHECK (1 OF 2)

Test your understanding of validation annotations, exception handling, standard error responses, and HTTP status codes.

1. Which annotation is used to trigger input validation in Spring Boot?

A. @Valid

B. @ValidateInput

C. @ValidRequest

D. @CheckInput

2. Where should you handle exceptions centrally in a Spring Boot REST API?

A. In each service method

B. In each controller method

C. Using @ControllerAdvice and @ExceptionHandler

D. In the repository layer

3. What is the purpose of a standard error response model?

A. To hide exception details from logs

B. To provide inconsistent responses

C. To return consistent, structured error information to clients

D. To replace HTTP status codes

4. Which HTTP status code is most appropriate for validation failures?

A. 200 OK

B. 400 Bad Request

C. 404 Not Found

D. 500 Internal Server Error

KEY TAKEAWAY @Valid triggers validation; @ControllerAdvice/@ExceptionHandler centralize handling; a standard error model returns consistent, structured information with 400 for validation failures.

KNOWLEDGE CHECK (2 OF 2)

Four more questions on error-handling best practices, testing tools, Bean Validation annotations, and internal-detail exposure.

5. Which of the following is a best practice for error handling?

A. Expose stack traces in responses

B. Return generic error messages

C. Log errors with context (requestId, path, userId, etc.)

D. Use different error formats in different APIs

6. Which tool is commonly used for API testing in this module?

A. Swagger UI

B. Postman

C. Jenkins

D. Elasticsearch

7. Which of the following is NOT a validation annotation in Bean Validation (JSR 380)?

A. @NotNull

B. @Email

C. @Size

D. @NotEmptyString

8. Why should internal error details not be exposed to API clients?

A. It improves response time

B. It reduces log size

C. It protects security and prevents information leakage

D. It is required by the HTTP specification

KEY TAKEAWAY Log with context, test with Postman, know the real Bean Validation annotations (@NotEmptyString is not one), and hide internal details to protect security.

"Validate early. Handle gracefully. Respond consistently."

MODULE 29 COMPLETE

Validation and Global Exception Handling

You can now validate request data with Bean Validation, centralize exception handling with @ControllerAdvice, and return standardized, secure, user-friendly error responses.